

第四章：数据库安全性（授权）—— AI 讲解

根本矛盾

数据库的初衷是让数据能被共享使用。但共享意味着更多人接触到数据，风险就更大。

整个第四章的核心问题：怎么让该用的人能用，不该用的人用不了？

一、不安全因素 —— "你家可能被偷的三种方式"

因素	大白话
非授权用户恶意存取	小偷翻墙进来了
数据库中重要数据的泄露	你家窗户没关，路人瞄到了你的银行卡密码
安全环境的脆弱性	你家门锁是纸做的

这三个是递进关系：有人想搞你 → 数据本身敏感 → 环境还不靠谱。三条全中，必出事。

二、安全性控制手段 —— "从进门到出门，层层设防"

手段	比喻	什么时候用
身份鉴别	进门刷脸	第一步，确认你是谁——有静态口令、动态口令、生物特征、智能卡等
存取控制（授权）	给你一把只能开某个房间的钥匙	核心，控制你能干啥
视图机制	不让你进厨房，但在墙上开个窗口让你看	只想让你看部分数据时
审计	家里装了摄像头	出了事能查是谁干的
数据加密	就算偷到了也是天书	数据被盗后的最后防线

恍然大悟点：这五层不是选一个，而是层层叠加的。身份鉴别挡不住内部人，授权管不了恶意DBA，审计防不了实时泄露，加密防不了有权限的人乱操作。每一层补上一层的漏洞。

三、GRANT 和 REVOKE —— "借钥匙和收回钥匙"

这是本章最核心的操作，也是考试最爱考的。

GRANT —— 借钥匙

```
GRANT SELECT ON TABLE Student TO U1;
```

翻译："我把 Student 表的查询权限这把钥匙，交给了 U1。"

发出 GRANT 的人可以是数据库管理员、数据库对象创建者、或已经拥有该权限的用户。
对象类型可以是 TABLE 或 VIEW。权限可以是 SELECT 等具体权限，也可以是 ALL PRIVILEGES。用

户名可以是指定用户，也可以是全体用户 PUBLIC。
WITH GRANT OPTION —— "你还可以复制钥匙"

```
GRANT SELECT ON TABLE Student TO U1 WITH GRANT OPTION;
```

翻译："U1 不仅自己能查 Student，还能把查询权限再转授给别人。"
恍然大悟点：为什么 SQL 要禁止循环授权？想想看：

- A 授权给 B
- B 授权给 C
- C 授权给 A

这时候如果 A 的权限被收回，理论上 B 和 C 的权限也应该消失，但 A 又从 C 那里获得了权限——这就成死循环了。所以 SQL 直接一刀切：你不能把权限往回传给给你授权的人。

REVOKE —— 收回钥匙

```
REVOKE SELECT ON TABLE Student FROM U1 CASCADE;
```

CASCADE vs RESTRICT 的区别，用一个场景秒懂：
你借给 U1 一把钥匙，U1 又配了一把给 U2。

- CASCADE：你收回 U1 的钥匙时，U2 的钥匙也自动作废。连锁反应。
- RESTRICT：你想收回 U1 的钥匙，但系统发现"等等，U1 已经把钥匙给别人了，你要是收回了，那 U2 怎么办？算了，我不让你收。"

所以 RESTRICT 不是"只收回一部分"，而是"发现有传播，直接拒绝整个操作"。

四、创建用户的三种权限 —— "三个级别的员工卡"

```
CREATE USER username [WITH DBA|RESOURCE|CONNECT];
```

权限	类比	能做什么	不能做什么
DBA	公司老板	建用户、创建模式、建表、建视图、授权	无限制
RESOURCE	部门经理	建表、建视图、把自己的权限给别人	不能建新用户，不能建模式
CONNECT	实习生	登录，等别人给你权限	啥也干不了

恍然大悟点：这三种权限是阶梯关系：

- CONNECT 是最底层，只有"入场券"
- RESOURCE 是中层，能"盖房子"（建表）但不能"批地"（建模式）
- DBA 是顶层，连"土地政策"都能定

考试最爱考的是：RESOURCE 能不能创建新用户？不能。为什么？因为创建用户是"发入场券"的权力，只有老板（DBA）才有。

五、角色 —— "别再一个个发钥匙了"



没有角色的时候，你要给 10 个人相同的权限，你得写 10 次 GRANT。如果有人权限要调整，你又得改 10 次。

角色的思路是：

1. 创建一个角色"教师"
2. 把"查询成绩"的权限给"教师"这个角色
3. 把张三、李四、王五都加到"教师"角色里

恍然大悟点：角色是权限的集合，不是用户的集合。你是把权限打包成一个"权限包"，然后把用户丢进这个包。这样改权限时只需要改角色的权限，所有角色成员自动生效。

WITH ADMIN OPTION 和 GRANT 的 WITH GRANT OPTION 有什么区别？考试必考：

选项	用在	传播的是什么
WITH GRANT OPTION	GRANT 权限时	传播的是具体权限
WITH ADMIN OPTION	GRANT 角色时	传播的是整个角色

六、一条逻辑主线串起所有知识点

不安全因素（为什么要搞安全）

↓

身份鉴别（先确认你是谁）

↓

GRANT/REVOKE（给你什么权限 / 收回什么权限）

└─ WITH GRANT OPTION（能不能转授）

└─ CASCADE / RESTRICT（收回时怎么处理连锁反应）

└─ 三种用户权限（DBA / RESOURCE / CONNECT）

↓

角色（批量管理权限，别一个个授权）

↓

视图 + 审计 + 加密（补充手段，层层加固）

整个第四章就一件事：把"谁"能对"什么数据"做"什么操作"控制得明明白白。

